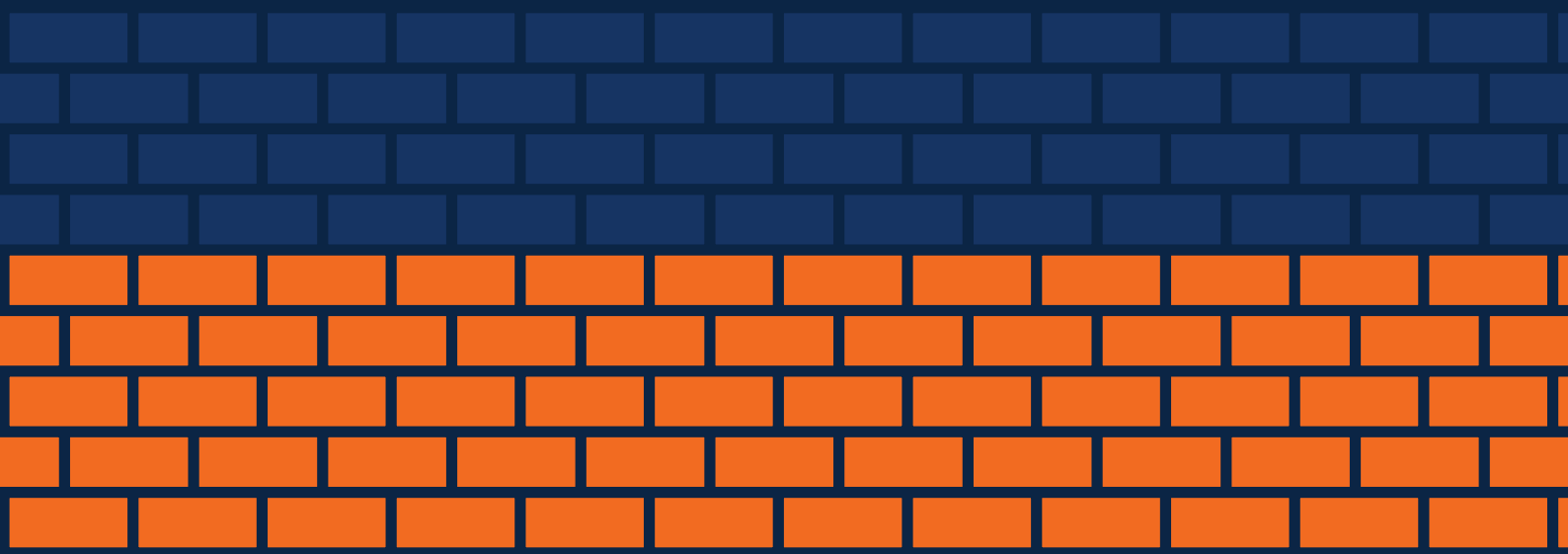
Firewalls and Antivirus Explained

From packet filters to EDR: how firewalls and antivirus work, how they differ from routers, Layer 3 switches and each other, and how to choose the right protection

A PRACTICAL GUIDE FOR IT PROFESSIONALS AND STUDENTS



Prepared by Jahir | IT Systems Administrator

Edition 2026

CONTENTS

What is inside this guide

What Is a Firewall? . . . 3
A Short History: How Firewalls Entered IT . . . 4
Why Do We Need a Firewall? . . . 5
How a Firewall Works . . . 7
Types of Firewalls . . . 8
Firewall vs Router vs Layer 3 Switch . . . 10
Firewall vs Other Security Tools . . . 13
Antivirus: What It Is and How It Differs from a Firewall . . . 14
How Antivirus Detects Threats . . . 15
AV, NGAV, EPP, EDR, XDR and MDR . . . 16
Antivirus and Endpoint Products You Will Meet . . . 17
How to Evaluate Antivirus Software . . . 18
Firewall and Antivirus Together: Layered Defence . . . 19
Where Firewalls Sit: Network Design and Zones . . . 20
Firewall Sizes, Tiers and Datasheets . . . 22
Firewall Products You Will Meet in the Market . . . 24
Choosing the Right Firewall . . . 25
Reference Designs: Three Sample Networks . . . 26
A Simple Buying Flow . . . 27
Best Practices for Running a Firewall . . . 28
Firewall Go-Live Checklist . . . 29
Frequently Asked Questions . . . 30
The Future of Firewalls . . . 31
Glossary and Key Takeaways . . . 31

Who this guide is for

System administrators, help desk engineers, networking students, IT managers and anyone who hears the word "firewall" every day but has never seen the whole picture in one place. No vendor sales language, no heavy math: just clear explanations, comparisons and practical advice.

Vendor-neutral by design

This guide explains concepts and does not recommend, rank or compare any brand or product. Commonly available products are named for general awareness only. Features, licensing and terminology change over time, so always confirm details in the official documentation of whichever product you use.

CHAPTER 1

What Is a Firewall?

A **firewall** is a security control that sits between networks and decides which traffic is allowed to pass and which must be blocked. It compares every connection against a set of rules (a *policy*) written by the administrator. If the traffic matches an allow rule, it passes. If it does not, it is dropped and usually logged.

The name comes from construction. A building firewall is a fire-resistant wall that stops a fire in one section from spreading to the next. A network firewall plays the same role: if something goes wrong in one network (an infected laptop, a hacked website, a compromised guest device), the firewall limits how far the damage can travel.

The simplest way to picture it

Think of the security desk at the entrance of a company building. The guard checks who you are, where you want to go, and whether you are allowed. Visitors get a badge for the meeting room only. Deliveries stop at the loading bay. Someone with no appointment does not get in at all. A firewall does the same for data packets: it checks **source**, **destination**, **service** and, in modern devices, **who the user is** and **which application** is really being used.

What a firewall can do

- **Filter traffic** by IP address, port, protocol, zone, user, application, country or URL category.
- **Separate networks** into zones such as inside, DMZ, guest and IoT so a problem in one zone stays there.
- **Hide internal addresses** using NAT (Network Address Translation) so internal devices are not directly reachable.
- **Create secure tunnels**: site-to-site VPN between offices and remote access VPN for staff.
- **Inspect content** with intrusion prevention, anti-malware, web filtering and TLS/SSL inspection (in next-generation models).
- **Record everything**: logs that feed audits, troubleshooting and security investigations.

What a firewall cannot do

A firewall is powerful but it is not magic. It cannot stop a user from typing their password into a fake login page, cannot see inside encrypted traffic unless configured to, cannot protect a laptop that is

outside the office network, and cannot fix a badly written rule set. It is one layer in a **defence-in-depth** design that also includes patching, endpoint protection, multi-factor authentication, backups and trained users.

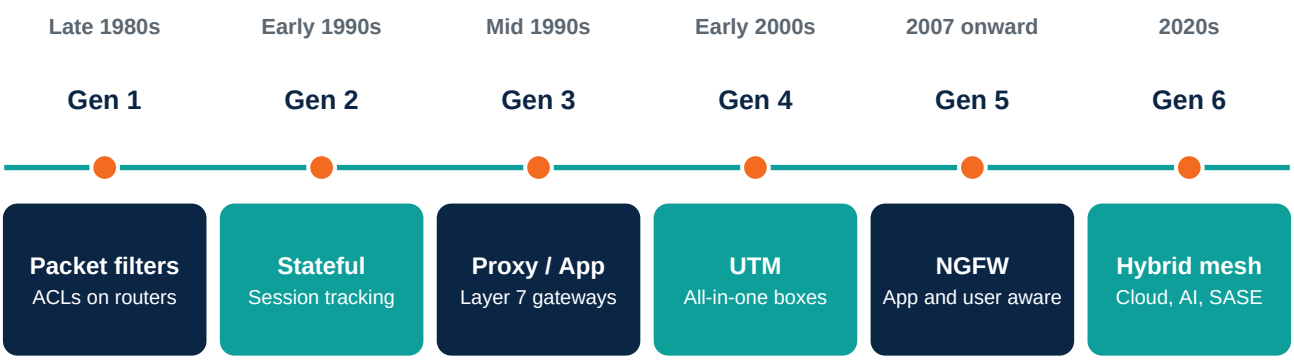
> **Key takeaway**
> A firewall enforces a written policy at the boundary between networks. Its value depends on the quality of that policy, not just on the brand of the box.

CHAPTER 2

A Short History: How Firewalls Entered IT

From a worm that slowed the early internet to AI-assisted cloud security.

Firewalls did not exist in the early days of networking. Universities and research labs trusted each other, and the internet was small. That changed quickly, and each change in the threat landscape produced a new generation of firewall.



The trigger: the late 1980s

In November 1988 the **Morris Worm** spread across a large share of the computers then connected to the internet and made many of them unusable. It showed that a connected network could be attacked from anywhere, and that being on the network did not mean being trustworthy. Around the same period, engineers at companies and research labs began placing routers with access lists between their internal networks and the outside world. These early packet filters were the first firewalls.

Generation 1: packet filters (late 1980s)

A packet filter looks at each packet on its own and checks the header: source IP, destination IP, protocol and port. It is fast and simple, but it has no memory. It cannot tell whether a reply packet belongs to a real conversation or is a forged one. Administrators had to open wide port ranges to let replies come back, which created gaps.

Generation 2: stateful inspection (early 1990s)

Stateful firewalls added a **session table**. When an inside user starts a connection, the firewall remembers it, and only replies that match that session are allowed back in. Commercial products in the early 1990s made stateful inspection widely available, and later open-source firewalls such as Linux netfilter/iptables adopted the same idea. Stateful inspection is still the foundation of every modern firewall.

Generation 3: application layer and proxy firewalls (1990s)

Attackers learned to hide inside allowed ports, especially port 80 for web traffic. Proxy firewalls stood in the middle of the conversation, terminated the connection, and inspected the actual application data (HTTP, FTP, SMTP) before passing it on. They were more secure but slower and needed a dedicated proxy for each protocol.

Generation 4: UTM, Unified Threat Management (early 2000s)

Small and mid-sized companies could not afford separate boxes for firewall, VPN, antivirus, web filter and IPS. Manufacturers combined everything in one appliance. Custom chips (ASICs) made it possible to run those services without collapsing performance. The term UTM is still used for SMB products today.

Generation 5: Next-Generation Firewall, NGFW (2007 onward)

Around 2007 a new type of firewall appeared that classified traffic by **application** and **user** instead of only by port. The idea was simple: port 443 no longer tells you whether the traffic is a business tool, a file-sharing site or malware. Over the following years the idea became standard, and today most enterprise firewalls are called next-generation firewalls.

Generation 6: hybrid mesh and cloud-delivered security (2020s)

Networks now span head offices, branches, data centres, several clouds and remote users. Analysts have started to describe the market as **hybrid mesh firewall**: physical appliances, virtual firewalls and cloud services managed under one policy and one console. Features such as SD-WAN, ZTNA (Zero Trust Network Access), SASE and machine-learning threat detection are now part of the conversation.

> **Key takeaway**
>
> Every generation solved a weakness of the previous one: no memory (Gen 1), no application awareness (Gen 2), poor speed (Gen 3), too many boxes (Gen 4), port-only decisions (Gen 5), and distributed networks (Gen 6).

CHAPTER 3

Why Do We Need a Firewall?

Any device with an IP address that can be reached from the internet is scanned within minutes. Automated tools probe every public address, looking for open remote desktop ports, outdated web servers, exposed databases and weak VPN gateways. Inside the network, the risk is different: one infected or careless device can attack every other device it can reach. A firewall addresses both problems.

The main reasons organisations deploy firewalls

Reason	What it means in practice
Block unwanted inbound traffic	Only the services you publish (for example a website or VPN) are reachable from the internet. Everything else is silently dropped.
Control outbound traffic	Stops malware from calling home, blocks risky categories (proxy avoidance, malware sites), and limits data leaving the company.
Segment the network	Separates servers, staff, guests, CCTV, printers and IoT so an incident in one zone does not spread to the rest (lateral movement).

Reason	What it means in practice
Secure remote access	Provides site-to-site VPN for branches and remote-access VPN for staff, with authentication and encryption.
Enforce identity-based policy	Rules like "Finance group may reach the accounting server" instead of "this IP may reach that IP".
Meet compliance requirements	Standards such as PCI DSS, ISO 27001, SOC 2 and national cybersecurity frameworks expect network boundary controls, logging and review.
Provide visibility	Logs show who talked to what, when and how much. This is the first place to look during an incident or a slow-network complaint.
Hide the internal design	NAT and proxying prevent outsiders from mapping internal addresses and services.

Typical attacks a firewall helps reduce

Threat	How the firewall helps
Port scanning and reconnaissance	Default-deny inbound policy and scan-detection features reveal nothing useful to the scanner.
Brute force on RDP, SSH, VPN	Services are not exposed at all, or exposed only to allowed countries/IPs, with rate limits and lockouts.
Exploitation of known vulnerabilities	IPS signatures and virtual patching block known exploit patterns while the server waits for a patch window.
Malware and ransomware delivery	Anti-malware, sandboxing, URL filtering and DNS security stop many downloads and command-and-control connections.
Denial of service (DoS)	Connection limits, SYN-flood protection and rate limiting keep the firewall and servers alive under moderate attacks.
Lateral movement inside the network	Internal segmentation firewalls restrict which zones can talk to each other, limiting how far an attacker gets.
Data exfiltration	Outbound policy, application control and DLP (in some models) restrict uploads to unapproved services.

Why not just use antivirus and passwords?

Endpoint protection and strong authentication are essential, but they act on the device or the account. A firewall acts on the **network path** and protects devices that cannot protect themselves: printers, CCTV cameras, industrial controllers, old servers and guest phones. It also gives one central place to apply a rule for hundreds of devices at once. Neither control replaces the other.

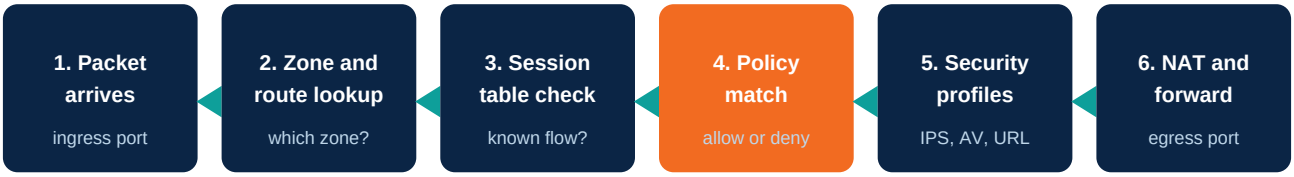
> **Real-world view**
>
> Small offices often say "we are too small to be attacked". Automated attacks do not choose targets by size. They scan everything, and the cheapest victims are the ones with no perimeter control.

CHAPTER 4

How a Firewall Works

The journey of one packet.

Whether the device is a small desktop unit or a data-centre chassis, the logic is similar. Every packet passes through a series of checks. The details differ between vendors, but the flow below is a good mental model.



If the packet belongs to an existing allowed session, steps 4 and 5 are skipped or shortened (fast path).
If no policy matches, the implicit deny rule drops the packet and writes a log entry.

Rules and policy

A firewall policy is an ordered list of rules. The firewall reads from the top and applies the **first rule that matches**. A rule normally contains: source zone and address, destination zone and address, service or application, user or group, action (allow or deny), security profiles to apply, and logging options. The last rule is an implicit **deny all**.

#	Source	Destination	Service / App	Action	Comment
1	Any (Internet)	DMZ Web Server	HTTPS	Allow + IPS	Publish the company website
2	LAN Users	Internet	Web browsing (categories)	Allow + Web Filter	Staff internet access
3	Finance group	Accounting Server	SQL, HTTPS	Allow	Identity-based access
4	Guest Wi-Fi	LAN	Any	Deny + log	Guests can never reach the inside
5	Any	Any	Any	Deny + log	Implicit deny (default)

Stateful inspection

When a user on the LAN opens a website, the firewall creates an entry in its **session table** that records the addresses, ports and protocol. The return traffic matches that entry and is allowed automatically. A packet arriving from the internet that does not match any session and is not covered by a published-service rule is dropped. This is what allows outbound access without opening inbound doors.

NAT: Network Address Translation

Internal devices normally use private addresses such as 192.168.x.x or 10.x.x.x, which cannot be routed on the internet. The firewall translates them to a public address when traffic leaves (source NAT or PAT) and can forward incoming requests to an internal server (destination NAT or port forwarding).

NAT is not a security feature by itself, but together with stateful rules it hides the internal network.

Zones and interfaces

Modern firewalls group interfaces into **zones** (Inside, Outside, DMZ, Guest). Policy is written between zones. This makes rules readable: "Guest to Inside: deny" is easier to audit than a list of IP ranges.

Beyond ports: deep inspection

- **Application control** recognises the real application (for example Microsoft Teams, Dropbox, BitTorrent) even when it uses port 443.
- **IPS (Intrusion Prevention)** compares traffic to signatures of known exploits and abnormal behaviour and drops matches.
- **Anti-malware and sandboxing** scan files in transit, and unknown files may be detonated in a cloud sandbox.
- **Web and DNS filtering** blocks categories of sites and known malicious domains.
- **TLS/SSL inspection** decrypts, inspects and re-encrypts traffic. It reveals hidden threats but consumes a lot of CPU and raises privacy and certificate considerations.
- **Identity integration** links traffic to users through Active Directory, Entra ID, RADIUS or captive portals.

> **Why this matters when you compare models**
>
> Each extra inspection step costs performance. A datasheet may promise 10 Gbps of plain firewall throughput but only 1 Gbps once IPS, antivirus and TLS inspection are enabled. The chapter on comparing models shows how to read those numbers.

CHAPTER 5

Types of Firewalls

Firewalls can be classified by how they inspect traffic, by how they are delivered, and by where they sit.

By inspection method

Type	What it inspects	Strengths	Limitations
Packet filter	Headers only (IP, port, protocol)	Very fast, low cost, built into routers and L3 switches	No session memory, no application awareness
Stateful firewall	Headers plus connection state	Solid baseline, efficient, widely supported	Cannot tell which application is using a port
Proxy / application gateway	Full application payload, terminates the session	Deep inspection and strong isolation	Slower, protocol-specific
UTM	Stateful + IPS, AV, web filter, VPN in one box	One appliance for small sites, simple to buy	Performance drops when all services are on
NGFW	Application, user, content, threat intelligence	Granular policy, modern threat prevention	Higher cost, more complex, needs tuning and licences
WAF	HTTP/HTTPS requests to web applications	Blocks SQL injection, XSS, bot abuse	Protects web apps only, not a general firewall

By form factor

Form factor	Description	Examples of use
Hardware appliance	Purpose-built box, often with custom silicon for speed	Head office, branch, data centre edge
Virtual appliance	Same firewall software as a virtual machine (VMware, Hyper-V, KVM)	Private cloud, lab, east-west traffic in virtual data centres
Cloud-native firewall	Managed service offered by a cloud provider (offered by the cloud platform itself)	Protecting cloud virtual networks
Firewall as a Service (FWaaS)	Delivered from the vendor cloud as part of SASE	Roaming users and small branches with no local appliance
Host-based firewall	Software on the operating system (the operating system firewall, iptables, nftables)	Servers and laptops as a second line of defence
Open-source firewall	Free software on commodity hardware (community-maintained projects)	Labs, education, cost-sensitive deployments

By position in the network

- **Perimeter (edge) firewall** between the company and the internet.
- **Internal segmentation firewall (ISFW)** between departments or server zones.
- **Data-centre firewall** for high-throughput north-south and east-west traffic.
- **Branch firewall** often combined with SD-WAN and local internet breakout.
- **Cloud firewall** inside the virtual networks of public cloud platforms.

CHAPTER 6

Firewall vs Router vs Layer 3 Switch

Three devices that all "route", but for very different reasons.

This is one of the most common questions from beginners and even from experienced IT staff, because all three devices can forward packets between networks, and the boundaries have blurred over the years. The clearest way to separate them is by asking: **what is the device's main job?**

Device	Main job	One-line summary
Router	Connect different networks and choose the best path between them	The traffic director
Layer 3 switch	Switch inside the LAN at wire speed and route between VLANs	The fast internal junction
Firewall	Decide whether traffic is allowed and inspect it for threats	The security guard

The router

A router connects separate IP networks, for example your office LAN and your ISP. It keeps a **routing table**, uses static routes or dynamic protocols (OSPF, BGP, EIGRP) to find the best path, and forwards packets accordingly. Routers typically provide WAN interfaces (Ethernet, fibre, serial, LTE), NAT, DHCP, QoS and basic access control lists (ACLs). Some also run IPsec VPN or a zone-based firewall feature. But security is a secondary function; the router is optimised for path selection and connectivity.

The Layer 3 switch

A Layer 3 switch is a switch that can also route between VLANs. Routing is done in hardware (ASIC), which makes inter-VLAN traffic extremely fast and inexpensive per port. It is the standard core or distribution device in a campus network: users and servers sit in different VLANs, and the L3 switch holds a virtual interface (SVI) for each VLAN as the default gateway. It supports static routing and often OSPF, plus ACLs. It does not normally do NAT for the internet, deep inspection, or advanced VPN, and its ACLs are usually **stateless**.

The firewall

A firewall exists to enforce security policy. It is **stateful** by design, understands zones, applies NAT, terminates VPNs, and (in NGFWs) inspects applications, users and content. It can route, and in small networks it often acts as the only router, but it is not built to carry huge volumes of internal east-west traffic across dozens of VLANs at wire speed.

Which OSI layers does each device work on?

OSI layer	L2 Switch	L3 Switch	Router	Stateful FW	NGFW
7 Application					**Yes**
6 Presentation					**Yes**
5 Session					**Yes**
4 Transport		Basic	Basic	**Yes**	**Yes**
3 Network		**Yes**	**Yes**	**Yes**	**Yes**
2 Data Link	**Yes**	**Yes**	**Yes**	**Yes**	**Yes**
1 Physical	**Yes**	**Yes**	**Yes**	**Yes**	**Yes**

Green = full capability. Orange = limited or basic capability (for example L3 switch ACLs on ports).

Side-by-side comparison

Feature	Router	Layer 3 switch	Firewall (NGFW)
Primary purpose	Inter-network routing, WAN connectivity	High-speed LAN switching and inter-VLAN routing	Security enforcement and threat prevention
Forwarding method	Software or hardware, routing table	Hardware ASIC, wire-speed	Session-based, security engine plus fast path
Stateful inspection	Limited (zone-based feature on some)	No (stateless ACLs)	Yes, core function
Application awareness	No / limited	No	Yes (App-ID, application control)
User identity in policy	No	No	Yes (AD, RADIUS, SSO)
IPS, anti-malware, web filter	No (optional add-ons)	No	Yes (licensed subscriptions)
NAT	Yes	Rare	Yes, advanced options
VPN	IPsec on many models	Usually no	IPsec and SSL VPN, remote access
Dynamic routing (OSPF, BGP)	Full support	OSPF, sometimes BGP	Supported but not the focus
WAN interfaces (LTE, serial, DSL)	Yes, wide variety	No	Limited, mostly Ethernet
Port density	Few to moderate	24 to 48+ ports typical	Few to moderate
Typical throughput	Mbps to tens of Gbps	Hundreds of Gbps switching capacity	Depends heavily on features enabled
Logging and visibility	Basic (syslog, NetFlow)	Basic	Rich: sessions, apps, users, threats
Typical price/performance	Medium	Well suited to internal traffic	Higher, plus subscription licences

Where each one sits in a typical design

In a well-built small or medium network the order from outside to inside is usually: **ISP router or modem, then firewall, then Layer 3 core switch, then access switches and Wi-Fi**. The router hands over the internet link. The firewall guards the boundary and separates zones. The Layer 3 switch carries the internal VLAN traffic quickly. In smaller offices a single firewall may do all three jobs, and in large enterprises the firewall may be placed in front of the data centre while routers handle WAN and BGP.

Common misunderstandings

- **"My router has a firewall, so I do not need one."** A router ACL or basic NAT is not the same as a stateful, application-aware policy with logging and threat prevention.
- **"A Layer 3 switch with ACLs replaces a firewall."** Switch ACLs are stateless and have no inspection. They are useful for basic VLAN restrictions but are not a substitute.
- **"Firewalls are just routers with a security tab."** Firewalls maintain state for millions of sessions and run inspection engines. That is very different from forwarding packets.
- **"Put the firewall in the core to inspect everything."** Routing all inter-VLAN traffic through a firewall can create a bottleneck. Many designs route on the L3 switch and send only sensitive zones through the firewall.

A worked example: one user opens a website

Follow a single request from a staff laptop in VLAN 20 to a public website and back. This is where the three roles become obvious.

Step	Device	What it does
1	Access switch (Layer 2)	Receives the frame from the laptop and forwards it inside VLAN 20 by MAC address. It has no idea about the website.
2	Layer 3 switch	The laptop's default gateway lives here (the VLAN 20 SVI). It sees the destination is outside the local subnets and routes the packet at wire speed towards the firewall. A basic ACL may allow or deny by port.
3	Firewall	Checks the zone, creates a session entry, matches the policy ("Staff to Internet: allow, web filter on"), applies IPS and URL filtering, translates the private address with NAT, and logs the session.
4	ISP router / modem	Forwards the packet to the provider network using its routing table. Behind the scenes, provider routers use BGP to find the path to the website.
5	Return path	The reply comes back to the firewall, matches the session table, is reverse-translated by NAT, inspected again, and is routed by the Layer 3 switch back to VLAN 20 and the laptop.

Rule of thumb

Use the **router** to reach other networks, the **Layer 3 switch** to move traffic quickly inside, and the **firewall** to decide what is allowed to move at all. In small networks one box may play all three roles, but the roles remain different.

CHAPTER 7

Firewall vs Other Security Tools

How firewalls fit with IDS/IPS, WAF, proxies and endpoint security.

Tool	What it does	How it differs from a firewall
IDS	Watches a copy of traffic and raises alerts on suspicious behaviour	Detects only, does not block. Sits out of line.
IPS	Sits in line and blocks traffic that matches attack signatures	Focused on exploits. Now built into NGFWs as a feature.
Proxy / Secure Web Gateway	Terminates web sessions and filters browsing	Focused on web traffic and users. Cloud SWG is part of SASE.
WAF	Protects a specific website or API from web attacks	Understands HTTP logic (SQL injection, XSS). Not a general network firewall.
Antivirus / EDR	Runs on the endpoint and detects malicious files and behaviour	Protects the device even off-network. Cannot control the network path.
NAC	Decides whether a device may join the network at all	Works at connection time (802.1X, MAC), while the firewall works on traffic.
SIEM	Collects and correlates logs from many systems	Analyses events. Firewalls are one of its main log sources.
ZTNA	Grants per-application access based on identity and device health	Replaces broad VPN access. Complements the firewall rather than replacing it.
SASE	Cloud-delivered bundle: SD-WAN, SWG, CASB, ZTNA, FWaaS	A delivery model that includes firewall functions in the cloud.

Ten common firewall myths

Myth	Reality
"NAT is a firewall."	NAT changes addresses. Security comes from the stateful policy that goes with it.
"Port 443 traffic is safe."	Malware and data theft also use HTTPS. Without inspection or application control you cannot tell the difference.
"A bigger box is always more secure."	Security depends on configuration, patching and features enabled, not only on size.
"Once installed, a firewall runs itself."	Rules, signatures, firmware and licences need regular attention.
"Our internal network is trusted."	Infected laptops and stolen credentials make the inside dangerous too. Segment it.
"Free open-source means less secure."	It can be very secure when maintained well. The risk is usually in operations, not licensing.
"We are too small to be targeted."	Attacks are automated and opportunistic. Small networks are common victims.
"Default deny breaks the business."	Default deny with well-documented allow rules is how most secure networks are run.
"The firewall log is only for emergencies."	Regular log reviews reveal misconfigurations, shadow IT and early signs of attacks.
"One firewall is enough for anything."	Critical sites need HA, and complex networks benefit from internal segmentation.

Key takeaway

A firewall is the traffic gate. The other tools watch, analyse or protect at other layers. Mature designs combine several of them.

CHAPTER 8

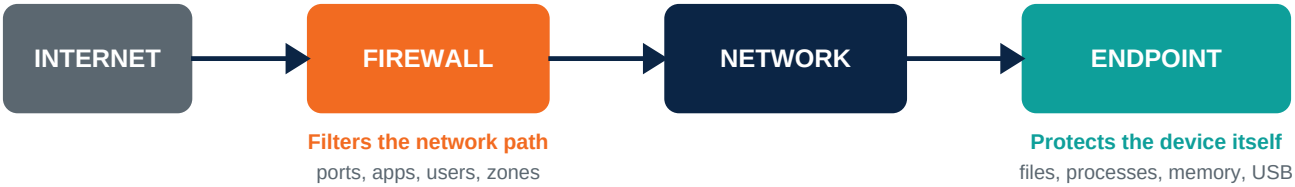
Antivirus: What It Is and How It Differs from a Firewall

Two tools that are often confused, and why you need both.

Antivirus (AV) is software installed on a device (laptop, desktop, server, phone) that detects, blocks and removes malicious software such as viruses, worms, trojans, ransomware, spyware and potentially unwanted programs. The name is historical: the first products in the late 1980s only searched for a small number of known viruses. Today the word usually covers a much broader **endpoint protection** product.

The simplest way to separate the two: a **firewall guards the doors of the building** (the network), while **antivirus is the security team inside each room** (the device). A firewall decides which connections may exist. Antivirus decides whether a file, process or behaviour on a device is safe.

Two different control points on the same journey



Side-by-side comparison

Aspect	Firewall	Antivirus / endpoint protection
Where it runs	Network boundary or between zones (appliance, virtual or cloud)	On each endpoint: laptop, desktop, server, phone
What it protects	The network path and everything behind it	The individual device and its data
What it inspects	Packets, sessions, applications, users, URLs, network content	Files, processes, memory, registry, scripts, behaviour, email attachments
Main question it answers	"Is this connection allowed?"	"Is this program or file malicious?"
Typical actions	Allow, deny, log, inspect, NAT, VPN	Scan, quarantine, delete, block process, roll back changes, isolate the device
Works when the device is off-network	No, protects only traffic passing through it	Yes, travels with the laptop
Sees encrypted traffic	Only with TLS inspection	Yes, after it is decrypted on the device

Aspect	Firewall	Antivirus / endpoint protection
Protects devices that cannot run software	Yes (printers, CCTV, IoT)	No, needs an agent
Stops USB and local file threats	No	Yes
Stops network scans and exposed-service attacks	Yes	Limited
Managed from	Firewall management console	Endpoint security console
Licensing	Per device, with subscriptions	Per user or per endpoint, per year

Key takeaway

Firewall and antivirus protect different things. A firewall cannot clean an infected laptop that connects from a hotel, and antivirus cannot stop an attacker scanning your exposed servers. Mature environments use both.

CHAPTER 9

How Antivirus Detects Threats

From simple signatures to behaviour and machine learning.

No single detection method catches everything. Modern products combine several. Understanding them explains why two products with the same name on the box can behave very differently.

Method	How it works	Strength	Weakness
Signature-based	Compares files with a database of known malware fingerprints (hashes and patterns)	Fast, accurate for known threats, few false alarms	Blind to new or modified malware
Heuristic / static analysis	Examines a file's structure and code for suspicious traits without running it	Catches variants of known families	More false positives, can be evaded by packing or obfuscation
Behaviour monitoring	Watches what a program does: encrypting many files, injecting into processes, disabling security tools	Catches new and fileless threats and ransomware	Detects only after activity starts, needs tuning
Machine learning / AI	Models trained on millions of samples score files and behaviours as good or bad	Detects unknown malware before it runs	Can produce false positives, quality depends on training data
Cloud reputation	Checks file, URL or publisher reputation against a cloud service	Very fast response to new outbreaks	Needs internet connectivity for best results
Sandboxing	Runs a suspicious file in an isolated environment and observes it	Great for zero-day and evasive files	Slower, some malware detects sandboxes
Exploit protection	Blocks techniques used to abuse vulnerabilities (memory attacks, script abuse)	Helps when a patch is not yet installed	Can break old or unusual applications
Web and email protection	Scans downloads, links and attachments, blocks malicious sites	Stops many attacks at delivery	Encrypted or novel lures may get through
Ransomware rollback	Keeps shadow copies and restores files after malicious encryption	Reduces damage	Not a replacement for backups

Method	How it works	Strength	Weakness
Application control	Allows only approved programs to run	Very strong against unknown software	High management effort

Test safely

The EICAR test file is a harmless text string that every antivirus product is designed to detect. Administrators use it to confirm that real-time protection and alerting are working, without touching real malware.

CHAPTER 10

AV, NGAV, EPP, EDR, XDR and MDR

Endpoint security vocabulary, translated.

Vendors use many acronyms, and marketing often mixes them. The table below shows what each one usually means and how they build on each other.

Term	Meaning	What it adds	Typical buyer
AV (traditional antivirus)	Signature-based scanning of files	Basic malware detection and cleaning	Home users, very small offices
NGAV (next-generation antivirus)	AV plus behaviour analysis and machine learning	Detects unknown and fileless threats, cloud-driven updates	Small and mid-size businesses
EPP (endpoint protection platform)	Complete prevention suite: NGAV, firewall, device control, web protection, encryption management	Central console, policies, reporting	Most organisations
EDR (endpoint detection and response)	Continuous recording of endpoint activity plus tools to investigate and respond	Threat hunting, timeline of an attack, isolate a machine, kill a process, remote response	Organisations with a security team or a service partner
XDR (extended detection and response)	EDR extended with email, identity, network, cloud and firewall data	Correlates events across systems into one incident	Mid to large enterprises
MDR (managed detection and response)	A service: the vendor's analysts monitor and respond 24x7	Expert eyes without hiring a full security team	Companies without a 24x7 SOC

Is the built-in operating system antivirus enough?

Modern operating systems include a built-in antivirus. For businesses the question is not detection alone but **management, reporting and response**: Can you see every device from one console? Can you investigate an alert, isolate a machine and report to management? Decide what you need in those areas, then choose the protection level that meets it, whether that is the built-in tool with a management layer or a separate endpoint platform.

Do not run two antivirus products at once

Two real-time scanners on the same machine compete for files and processes, slow the system and can cause crashes or missed detections. Operating systems often switch the built-in antivirus to a passive mode when another product is installed. Choose one primary engine.

CHAPTER 11

Antivirus and Endpoint Products You Will Meet

A general awareness list. Alphabetical order, no ranking.

How to read this list

These are commonly available business endpoint protection products, listed alphabetically for general awareness. It is not a ranking or a recommendation and it is not complete. Product names change often, and availability and regulations differ by country, so confirm details with each manufacturer and with your local requirements.

Manufacturer	Product line(s)	Category
Bitdefender	GravityZone	Endpoint protection and EDR
Broadcom (Symantec)	Symantec Endpoint Security	Endpoint protection and EDR
Check Point	Harmony Endpoint	Endpoint protection and EDR
Cisco	Secure Endpoint	Endpoint protection and EDR
CrowdStrike	Falcon platform	Endpoint protection, EDR and XDR
ESET	ESET PROTECT	Endpoint protection and EDR
Kaspersky	Kaspersky Endpoint Security	Endpoint protection and EDR
Malwarebytes	ThreatDown	Endpoint protection and EDR
McAfee	Consumer and business endpoint products	Antivirus and endpoint protection
Microsoft	Microsoft Defender Antivirus, Defender for Business, Defender for Endpoint	Built-in antivirus, endpoint protection, EDR and XDR
Palo Alto Networks	Cortex XDR	EDR and XDR
SentinelOne	Singularity platform	Endpoint protection, EDR and XDR
Sophos	Intercept X	Endpoint protection, EDR and XDR
Trellix	Trellix Endpoint Security	Endpoint protection and EDR
Trend Micro	Apex One, Trend Vision One	Endpoint protection, EDR and XDR

Well-known consumer antivirus brands for home users include Avast, AVG, Norton and McAfee. Many manufacturers also offer managed detection and response (MDR) services alongside their software.

CHAPTER 12

How to Evaluate Antivirus Software

What to check, where to find independent test data, and a vendor-neutral template you can reuse.

Marketing claims are hard to compare. A reliable approach is to use independent test results as one input and then to test a small shortlist in your own environment.

Independent sources

Source	What it tests	How to use it
AV-TEST	Protection, performance and usability for consumer and business products	Look at protection scores and performance impact across several months.
AV-Comparatives	Real-world protection, malware removal, performance, false alarms and business product tests	Look at multi-month results, not one month.
SE Labs	Realistic attack chains against endpoint products	Useful for how products handle full attacks.
MITRE ATT&CK; Evaluations	How well products detect and describe attacker techniques, mainly for EDR	Shows visibility and detail, not a pass or fail ranking.

The criteria that actually differ

Criterion	What to look at	Why it matters
Detection and prevention	Protection rate against zero-day and widespread malware, ransomware handling	The core job of the product.
False positives	How often legitimate software is blocked	Too many false alarms waste admin time and frustrate users.
Performance impact	CPU, memory, disk use, boot and application launch time	Slow computers lead users to disable protection.
EDR depth	Telemetry, search, timeline, isolate host, remote shell, response actions	Determines how well you can investigate and contain incidents.
Management console	Cloud or on-premises, multi-tenant, role-based access, reporting	Daily usability for a small team.
Deployment and integration	Intune, Group Policy, SCCM, scripts, Entra ID and Active Directory integration	Determines rollout effort.
Platform coverage	Windows, macOS, Linux, servers, mobile, virtual machines, legacy OS	Gaps become weak points.
Firewall and network integration	Shares status with the firewall to isolate infected hosts	Automated containment of an infected device.
Offline and low-bandwidth behaviour	Local engine strength, update size, cloud dependency	Important for remote sites and roaming laptops.
Tamper protection	Prevents users or malware from disabling the agent	Attackers try to switch off AV first.
Support and MDR	Local support, response time, 24x7 service options	Critical during an incident.

Criterion	What to look at	Why it matters
Licensing and total cost	Per user or device, term, add-ons, MDR, minimum quantities	The advertised price is rarely the final cost.

Scoring template for your own pilot

Install two or three products on a small group of representative machines for 2 to 4 weeks. Score each on a scale of 1 to 5, multiply by the weight, and total.

Criterion	Weight	Product A	Product B	Product C
Detection and prevention	25%			
False positives	10%			
Performance impact	15%			
Management console	15%			
EDR and response features	15%			
Integration with your environment	10%			
Support and cost	10%			
Weighted total	100%			

Adjust the weights to your priorities. A small team that cannot watch alerts may weigh management and MDR more heavily than raw EDR depth.

CHAPTER 13

Firewall and Antivirus Together: Layered Defence

Which control stops which attack, and how to run antivirus well.

Attack scenario	Firewall helps by	Antivirus / EDR helps by
Phishing email with a malicious attachment	Blocking known bad senders or files at the email gateway or sandbox	Scanning the attachment when opened and blocking the macro or script
Drive-by download from a compromised website	Web filtering and URL categories, IPS signatures	Blocking the downloaded payload and exploit behaviour
Malware on a USB drive	Cannot see it	Scans the device and blocks execution
Infected laptop working from home or a hotel	Only when the laptop connects through VPN	Protects the laptop everywhere
Malware calling home to a control server	Blocking known malicious IPs and domains, DNS security	Detecting the process and its behaviour, killing it
Attacker scanning and exploiting an exposed server	Blocks the ports, IPS stops the exploit	Detects post-exploit tools if the attacker succeeds
Ransomware spreading between computers	Segmentation limits reachable systems	Stops encryption behaviour and can isolate the host
Compromised IoT camera or printer	Isolates it in its own zone and limits outbound traffic	Not applicable, agent cannot be installed

Attack scenario	Firewall helps by	Antivirus / EDR helps by
Zero-day exploit in an application	IPS or virtual patching may block it	Exploit protection and behaviour detection may stop it

Running antivirus well: best practices

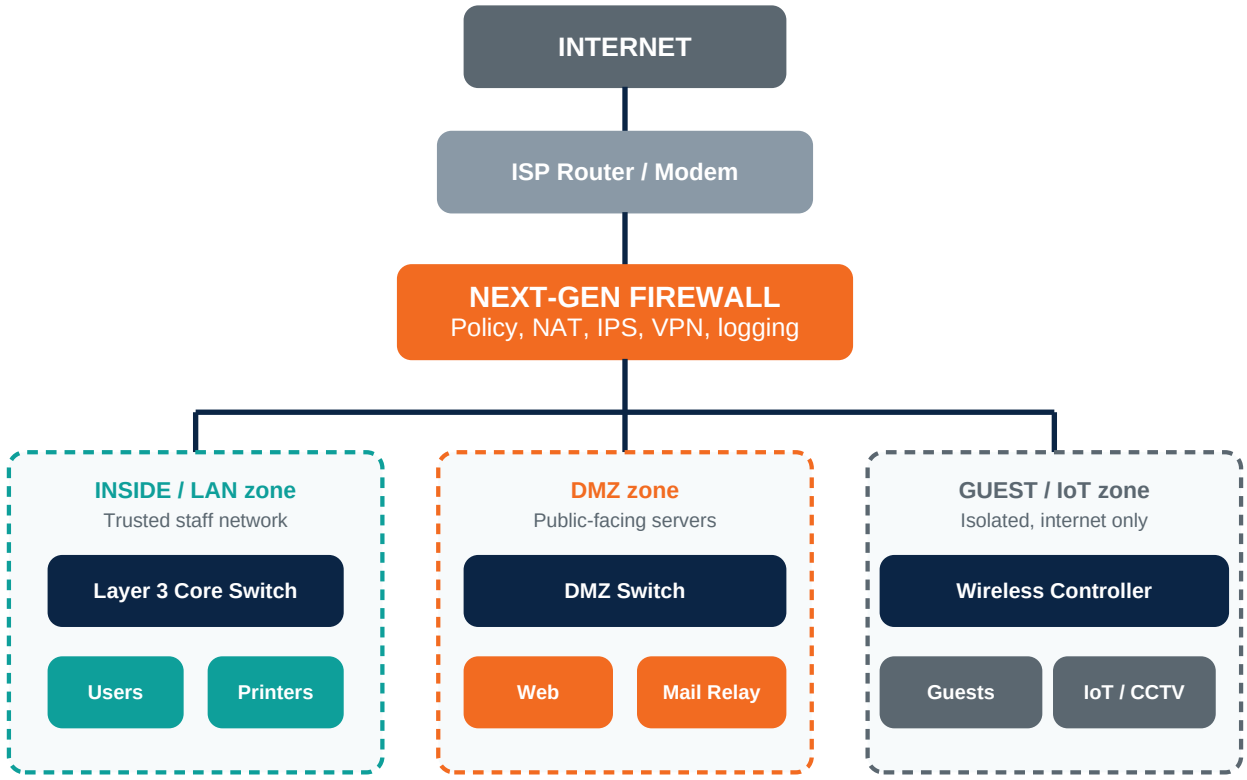
- Use **one** primary engine and manage it centrally. Unmanaged machines are the ones that get infected.
- Enable **real-time protection, cloud protection and tamper protection**. Keep definitions and the agent updated automatically.
- Keep exclusions to a minimum and document each one. Attackers look for excluded folders.
- Stage major agent updates on a pilot group first, then roll out in waves.
- Deploy **EDR** on servers and privileged admin machines even if you keep basic protection for the rest.
- Turn on **ransomware protection and controlled folder access** where suitable, and keep offline or immutable backups.
- Send endpoint alerts to the same place as firewall logs (SIEM, XDR portal) so incidents can be connected.
- Patch operating systems and applications. Antivirus is not a substitute for patching.
- Review the console weekly: unprotected devices, outdated agents, repeated detections on the same user.
- Educate users. Most infections still begin with a click.

> **Rule of thumb**
>
> Use the **firewall** to shrink what can reach you, the **antivirus/EDR** to catch what gets through on each device, and **backups** for the day both fail.

CHAPTER 14

Where Firewalls Sit: Network Design and Zones

A typical small to mid-size design places the firewall directly behind the ISP device and creates at least three zones: an **inside** network for staff, a **DMZ** for anything that must be reachable from the internet, and a **guest or IoT** zone that is isolated from everything internal. The diagram below shows this layout.



Design principles

- **Default deny between zones.** Open only what is required and document why.
- **Never place public-facing servers on the inside network.** Put them in a DMZ so a compromise cannot walk straight into the LAN.
- **Isolate guest Wi-Fi, IoT and CCTV.** These devices are the most likely to be unpatched.
- **Use two firewalls or a high-availability pair for critical sites.** A single firewall is a single point of failure.
- **Keep management interfaces off the internet.** Administer from a dedicated management network or via VPN with MFA.
- **Log to a central server.** Local logs are lost when the device fails or is compromised.

High availability (HA)

Two identical firewalls are configured as an **active-passive** or **active-active** cluster. They synchronise configuration and, in most cases, the session table, so failover happens in seconds and users do not lose connections. Almost all vendors require both units to be the same model and often matching licences.

Beyond the perimeter

Modern designs also add **internal segmentation firewalls** between server zones, virtual firewalls in the cloud, and remote-user protection through agents or SASE. The idea is called **zero trust**: never assume that traffic is safe just because it comes from inside.

CHAPTER 15

Firewall Sizes, Tiers and Datasheets

How firewalls are sized, and the datasheet numbers that actually matter.

Firewall manufacturers usually offer the same basic function in many sizes. The key is to understand the **size tiers** and to read the right performance figure. In most product lines, a **higher model number means a bigger, faster, more expensive box**, while the generation letter or suffix shows how recent the hardware is.

What is actually inside a firewall?

Understanding the hardware helps explain why two boxes with similar-looking ports can cost very different amounts.

Component	Role	Why it changes price and performance
CPU (x86 or ARM)	Runs the operating system, policy engine and inspection software	More cores and higher clock speed mean more sessions and deeper inspection.
ASIC / network processor	Custom chips that forward packets and handle encryption in hardware	Big boost to throughput and VPN speed. Present mainly in mid and high-end models.
Memory (RAM)	Holds session tables, policy and signature databases	More RAM allows more concurrent sessions and more security features at once.
Storage (SSD / flash)	Stores firmware, logs, reports, sometimes packet captures	Local logging and reporting need an SSD. Some entry models have none.
Network ports	Copper Ethernet, SFP, SFP+, SFP28, QSFP	Faster ports and more ports cost more. Match them to your switches.
Power supplies and fans	Single or redundant, fixed or hot-swappable	Redundant supplies are standard in data-centre models, optional or absent in desktop units.
Special options	PoE, Wi-Fi, built-in LTE, bypass ports	Convenient for branches, adds cost and limits placement.

Typical tiers

Tier	Typical environment	What to expect
Desktop / SOHO	Home office, micro branch, shops (up to about 25 users)	Fixed ports, fanless, optional Wi-Fi or PoE, built-in VPN, basic security subscriptions
Branch / SMB	Small office or branch (25 to 200 users)	More ports, 1G/2.5G/10G uplinks, HA support, SD-WAN, good UTM performance
Mid-range / campus	Medium company or regional office (200 to 2,000 users)	Rack-mount, redundant power options, 10G ports, higher session counts
Enterprise / data centre	Large campus, data-centre edge, service provider	25G/40G/100G ports, multiple CPUs and ASICs, virtual systems, clustering
Chassis / hyperscale	Carrier and very large data centres	Modular blades, hundreds of Gbps to Tbps aggregate throughput

How to read a datasheet without being misled

Datasheets list several throughput numbers. They are measured under different conditions and are **not interchangeable**. The table below explains the common ones, from most optimistic to most realistic.

Datasheet figure	What it measures	How to use it
Firewall throughput	Plain stateful forwarding with large packets and no inspection	Marketing headline. Almost never the real-world number.
IPS throughput	Firewall plus intrusion prevention with typical traffic mix	Useful if IPS is the main extra feature.
NGFW throughput	Firewall + application control + IPS	Good baseline for a modern deployment.
Threat protection throughput	NGFW plus anti-malware and logging, sometimes sandboxing	**Best figure for sizing** if you will enable full protection.
SSL/TLS inspection throughput	Decrypting and re-encrypting HTTPS	Often a fraction of other numbers. Critical because most traffic is encrypted.
IPsec VPN throughput	Encrypted site-to-site tunnels	Important for branch and remote-access designs.
Concurrent sessions	Maximum simultaneous connections	Grows with users, IoT, cloud apps, P2P. Do not buy tight.
New sessions per second	How fast connections can be created	Matters for busy web, guest Wi-Fi and DNS-heavy networks.
Interfaces	Copper, SFP, SFP+, SFP28, QSFP	Match your switches and uplinks. Check PoE if needed.
Virtual systems / VDOMs	Logical firewalls in one box	Needed for multi-tenant, MSP, or strict separation.

Sizing tip

Take your real internet bandwidth, decide which security features you will enable, look at the vendor's **threat protection or NGFW throughput** for that model, and keep at least 30 to 50 percent headroom for growth and traffic spikes. If you plan to inspect TLS, compare the SSL inspection number as well.

CHAPTER 16

Firewall Products You Will Meet in the Market

A general awareness list. Alphabetical order, no ranking.

How to read this list

The names below are commonly available firewall products and product families, listed alphabetically within each group for general awareness. Being listed does not mean a product is recommended, and being missing does not mean it is unsuitable. The list is not complete, and product names change over time, so check each manufacturer's website for its current range.

Dedicated firewall and network security manufacturers

Manufacturer	Product line(s)	Type
Barracuda Networks	CloudGen Firewall	Hardware, virtual and cloud editions
Check Point	Quantum Spark, Quantum gateways, CloudGuard	Hardware, virtual and cloud editions
Cisco	Secure Firewall (formerly Firepower and ASA), Meraki MX	Hardware and virtual, with cloud-managed options
Fortinet	FortiGate	Hardware, virtual and cloud editions
Huawei	USG and HiSecEngine series	Hardware and virtual
Juniper Networks (HPE)	SRX Series	Hardware and virtual
Palo Alto Networks	PA-Series, VM-Series, CN-Series	Hardware, virtual and container editions
Sophos	XGS Series (Sophos Firewall)	Hardware, virtual and cloud editions
SonicWall	TZ, NSa, NSsp and NSv series	Hardware and virtual
Stormshield	SNS (Stormshield Network Security) series	Hardware and virtual
WatchGuard	Firebox T and M series, Firebox Cloud	Hardware, virtual and cloud editions
Zyxel	USG FLEX and ATP series	Hardware

Router and network-equipment vendors with built-in firewall features

Manufacturer	Product line(s)	Type
MikroTik	RouterOS devices	Router hardware with a built-in firewall engine
Ubiquiti	UniFi gateways	Gateway hardware with built-in firewall features

Open-source firewall software

Project	What it is	Type
iptables / nftables	Packet filtering built into the Linux kernel	Software, command line

Project	What it is	Type
OPNsense	Community-driven firewall and router distribution	Software on standard hardware or virtual machine
pfSense (Netgate)	Firewall and router distribution, also sold on Netgate appliances	Software or appliance
VyOS	Network operating system with firewall and routing features	Software on standard hardware or virtual machine

Cloud platform firewalls

Cloud platform	Firewall service	Type
Amazon Web Services	AWS Network Firewall, security groups	Managed cloud service
Google Cloud	Cloud Firewall, firewall policies	Managed cloud service
Microsoft Azure	Azure Firewall, network security groups	Managed cloud service

Host-based firewalls

Every major operating system also ships with a firewall on the device itself, such as the Windows firewall, the macOS application firewall and Linux iptables or nftables. These protect one computer and complement, rather than replace, a network firewall.

CHAPTER 17

Choosing the Right Firewall

There is no best firewall, only the best fit. Work through these questions in order before requesting quotes.

Question	Why it matters
How many users and devices (including IoT and Wi-Fi)?	Drives concurrent sessions and licence counts.
What is the internet bandwidth now and in three years?	Sets the minimum threat-protection throughput.
Which features will actually be enabled? (IPS, AV, web filter, TLS inspection, sandbox)	Determines which datasheet number to use.
Single site or many branches?	Multi-site needs central management, SD-WAN and zero-touch provisioning.
Is high availability required?	Doubles hardware and often licences.
On-premises, cloud, or both?	Points towards hybrid mesh options or virtual firewalls.
Who will manage it, and what skills exist?	A powerful product with no skilled operator is a risk. Consider training or managed services.
What is the 3 to 5 year total cost?	Hardware is often less than half of the cost. Add subscriptions, support, HA unit, training and renewal.
Are there compliance or certification requirements?	Look for FIPS 140, Common Criteria and local approvals if required.
How good is local support and spare-part delivery?	Downtime cost usually exceeds the price difference between products.

Common buying mistakes

- Sizing by the "firewall throughput" number and then enabling IPS, antivirus and TLS inspection.
- Forgetting the licences: without active subscriptions many features stop updating or stop working.
- Buying a single unit for a business-critical site without a spare or HA partner.
- Ignoring interface types and ending up without SFP+ ports for the switch uplink.
- Choosing only by price or brand recognition and not checking who will support it locally.
- Not planning the migration: rules, NAT, VPNs and routing must be recreated and tested.

CHAPTER 18

Reference Designs: Three Sample Networks

How the ideas in this guide translate into real environments.

The examples below are generic and brand-neutral. Use them as a starting point for discussion, not as a bill of materials.

Design A: small office, about 25 users, one site

A single firewall doubles as the router and DHCP server. The ISP modem connects to the WAN port. Two or three VLANs (staff, guest, devices) are created on a small managed switch and trunked to the firewall, which is the default gateway for every VLAN. Remote staff use VPN with MFA.

Item	Recommendation
Firewall class	Desktop / SOHO tier with UTM subscription
Zones	Inside, Guest, optional IoT/CCTV
Key features	Web filtering, IPS, DNS security, remote-access VPN, scheduled config backup
Resilience	Spare unit or fast replacement agreement; cellular or second ISP failover if internet is critical
Biggest risk	Default passwords, exposed admin page, outdated firmware

Design B: medium company, about 150 users, head office plus two branches

A pair of firewalls in high availability protects the head office. A Layer 3 switch pair forms the core and routes between VLANs. Branches use smaller firewalls with SD-WAN over two ISPs and IPsec tunnels back to the head office. Servers live in a DMZ and an internal server VLAN.

Item	Recommendation
Firewall class	Branch/SMB tier at branches, mid-range tier in HA at head office
Zones	Inside, Servers, DMZ, Guest Wi-Fi, IoT/CCTV, Management
Key features	NGFW with application control, IPS, TLS inspection for user traffic, SD-WAN, site-to-site VPN, central management and logging
Routing	Layer 3 switch handles inter-VLAN routing; firewall guards the server and internet boundaries
Biggest risk	Rule sprawl, unmonitored logs, expired subscriptions at branches

Design C: data-centre edge and internal segmentation

High-throughput firewalls in a cluster protect the north-south path between users, the internet and applications. Internal segmentation firewalls or virtual firewalls control east-west traffic between application tiers. Everything is managed centrally and integrated with a SIEM.

Item	Recommendation
Firewall class	Enterprise / data-centre tier, clustered or HA, with 10G to 100G ports
Zones	Web tier, application tier, database tier, management, backup, partner access
Key features	Virtual systems, high session counts, IPS, API-driven policy, automation, detailed change tracking
Resilience	Active-active or active-passive across two racks or two sites, tested failover
Biggest risk	Overly permissive east-west rules and unmanaged exceptions

CHAPTER 19

A Simple Buying Flow

If you are starting from zero, follow these six steps. Most poor purchases skip one of them.

1 Define
Users, sites, bandwidth, features, compliance

2 Shortlist
Two or three vendors that fit skills and support

3 Size
Use threat protection and TLS numbers, add 30-50% headroom

4 Price 5 years
Hardware, licences, support, HA unit, training

5 Test
Proof of concept or lab unit with real traffic

6 Plan rollout
Migrate rules, NAT, VPN, routing; keep a rollback

Ask every vendor or reseller these questions

What throughput do I get with IPS, antivirus and TLS inspection enabled? What happens to features when a subscription expires? What is the replacement time for a failed unit in my country? Which firmware version do you recommend today and how often are security patches released?

CHAPTER 20

Best Practices for Running a Firewall

A firewall is only as good as its configuration and upkeep. These practices apply to any brand.

Area	Practice
Policy design	Default deny. Allow only what is needed. Write rules by zone, user group and application, not only by IP. Give every rule a comment and an owner.
Rule hygiene	Review rules at least quarterly. Remove unused, shadowed and expired rules. Avoid "any-any-allow".
Administration	Use named admin accounts with MFA. Restrict management access to a management network or VPN. Never expose the admin GUI to the internet.
Firmware and patching	Subscribe to vendor security advisories. Patch on a schedule and urgently for actively exploited vulnerabilities. Test in a lab or maintenance window first.
Backups	Back up the configuration after every approved change and store it off the device. Test that you can restore it.
Logging and alerting	Send logs to a central syslog or SIEM. Alert on admin logins, policy changes, VPN failures, IPS hits and high-risk denies.
VPN	Require MFA on remote access. Use modern cipher suites, disable legacy protocols, limit access to needed resources.
Threat features	Enable IPS, anti-malware and DNS/web filtering with automatic signature updates. Inspect TLS where legal and practical, with sensible exemptions.
Segmentation	Separate servers, users, guests, IoT and management. Restrict east-west traffic.
High availability	Test failover before an outage does. Keep spare units and licence information documented.
Change control	Record who changed what and why. Use a maintenance window and a rollback plan.
Documentation	Keep a current network diagram, IP plan, rule justification list and licence expiry dates.

Small-team tip

If you are the only administrator, automate the boring parts: scheduled config backups, licence expiry reminders, log forwarding and a monthly checklist. Consistency beats heroics.

CHAPTER 21

Firewall Go-Live Checklist

A printable list to review before and after a new firewall goes into production.

Before go-live	Done
Network diagram, IP plan and VLAN list are documented	[ ]
Rule list is reviewed and every rule has a purpose and owner	[ ]
Default passwords changed, admin accounts named, MFA enabled	[ ]
Admin access restricted to management network or VPN	[ ]
Firmware is on a recommended, current release	[ ]
Licences and subscriptions activated, expiry dates recorded	[ ]
Security profiles (IPS, AV, web/DNS filter) enabled and updating	[ ]
NTP time sync and DNS configured correctly	[ ]
Logging to central server or SIEM confirmed	[ ]
Configuration backup taken and restore tested	[ ]
HA pair tested: failover and failback	[ ]
VPN tunnels and remote access tested with real users	[ ]
Rollback plan and maintenance window agreed	[ ]

After go-live (first 30 days)	Done
Review logs for unexpected denies and unknown applications	[ ]
Tighten temporary "any" rules created during migration	[ ]
Check CPU, memory and session usage during peak hours	[ ]
Confirm scheduled backups and alerts are working	[ ]
Update documentation and hand over to support team	[ ]
Schedule the first quarterly rule review	[ ]

CHAPTER 22

Frequently Asked Questions

Q. Can a firewall replace a router?

In small networks, yes: many firewalls handle routing, NAT and DHCP. In larger or WAN-heavy networks, routers still handle path selection and special WAN links better.

Q. Can a Layer 3 switch replace a firewall?

No. It routes quickly between VLANs but lacks stateful inspection, application awareness and threat prevention.

Q. Do I still need a firewall if everything is in the cloud?

Yes, but it may be a cloud-native firewall, security groups or FWaaS instead of a physical box. The policy thinking is the same.

Q. Is a hardware firewall better than a software firewall?

They serve different roles. Hardware appliances protect the network boundary. Host-based software firewalls protect each device. Use both.

Q. What is the difference between UTM and NGFW?

UTM bundles many security services for small sites. NGFW emphasises application and user awareness and threat prevention. Today most products blur the line and vendors use both terms.

Q. Do I need to pay for subscriptions?

For real protection, usually yes. Without them the box acts mostly as a stateful firewall with no signature updates for IPS, antivirus or web filtering.

Q. Should I enable TLS inspection?

Most traffic is encrypted, so inspection greatly improves visibility. It needs CPU headroom, trusted certificates on devices and exemptions for banking, healthcare and privacy-sensitive categories.

Q. Do I need antivirus if I have a firewall?

Yes. A firewall cannot scan files on a device, stop malware from a USB drive, or protect a laptop that is off the office network.

Q. Is the built-in operating system antivirus enough?

For basic detection it may be. For a business, decide whether you also need central management, reporting, EDR and response tools.

Q. How often should I review firewall rules?

At least every quarter, and after every major project. Remove unused and duplicate rules and confirm each rule has an owner.

Q. Is open-source enough for a company?

It can be, if you have the skills, support plan and hardware quality to run it reliably. Many companies prefer a commercial vendor for support, warranty and advanced threat services.

Q. What happens if my firewall fails?

Without HA the network loses internet and inter-zone traffic until it is replaced. That is why critical sites use HA pairs or hold spare units with recent config backups.

CHAPTER 23

The Future of Firewalls

- **Hybrid mesh firewall:** one policy and one console across hardware, virtual and cloud firewalls, with API and DevOps integration.
- **SASE and SSE convergence:** firewall, secure web gateway, CASB and ZTNA delivered from the cloud, especially for remote users and small branches.
- **Zero trust:** access decisions based on identity, device posture and context instead of network location.
- **AI-assisted operations:** machine learning to detect anomalies, suggest rule clean-up and speed up investigation. Human review remains essential.
- **Encrypted traffic and quantum readiness:** more TLS 1.3 inspection challenges, and vendors adding post-quantum cryptography to VPNs and management.
- **Security in the network fabric:** switches, access points and SD-WAN edges enforcing policy together with the firewall.
- **Operational technology (OT) and IoT protection:** protocol-aware firewalls for industrial and building systems.

The appliance on the rack is not going away, but the function of a firewall is spreading across more places. The core skills stay the same: understand traffic, design zones, write clean policy and keep the system patched.

CHAPTER 24

Glossary and Key Takeaways

Glossary

Term	Meaning
AV / NGAV	Antivirus / Next-Generation Antivirus: detects and blocks malware on a device, NGAV adds behaviour and machine learning.
ACL	Access Control List: a simple list of permit and deny statements on a router or switch.
ASIC	Application-Specific Integrated Circuit: custom chip that speeds up forwarding or encryption.
DMZ	Demilitarised Zone: isolated network segment for public-facing servers.
EDR / XDR / MDR	Endpoint / Extended / Managed Detection and Response: detection, investigation and response tools and services.
EPP	Endpoint Protection Platform: complete prevention suite for devices.
FWaaS	Firewall as a Service: firewall functions delivered from the cloud.
HA	High Availability: two devices in a cluster so one can take over if the other fails.
IDS / IPS	Intrusion Detection / Prevention System.

Term	Meaning
NAT / PAT	Network Address Translation / Port Address Translation.
NGFW	Next-Generation Firewall: application, user and threat aware.
SASE / SSE	Secure Access Service Edge / Security Service Edge: cloud-delivered networking and security.
SD-WAN	Software-defined WAN: intelligent use of multiple links between sites.
SVI	Switch Virtual Interface: Layer 3 interface for a VLAN on a Layer 3 switch.
UTM	Unified Threat Management: firewall plus several security services in one box.
VLAN	Virtual LAN: logical separation of a switch into multiple broadcast domains.
ZTNA	Zero Trust Network Access: per-application access based on identity and posture.

Key points to remember

- A firewall enforces a written policy between networks and zones.
- Firewalls appeared in the late 1980s and evolved from packet filters to stateful, application-aware and now hybrid mesh designs.
- You need one because internet-facing systems are scanned constantly and internal networks need segmentation.
- A router finds paths, a Layer 3 switch moves internal traffic quickly, and a firewall decides what is allowed and inspects it.
- Small networks can combine roles in one device, but the roles stay different.
- Firewalls come in size tiers from desktop to data centre. Choose the tier by your users, bandwidth and the features you will enable.
- Read datasheets carefully: compare the same throughput figure, measured with the same features enabled.
- Size using threat protection and TLS inspection numbers, not the headline firewall number.
- Budget for subscriptions, support and a spare or HA unit, not just the hardware.
- Antivirus protects the device, the firewall protects the network path. They complement each other and neither replaces the other.
- Modern endpoint protection ranges from NGAV to EDR, XDR and MDR. Choose by your ability to monitor and respond, not by the acronym.
- Compare antivirus by independent test results, false positives, performance, console and EDR depth, then pilot two or three products.
- Patch, back up, log, review rules regularly, and document everything.

Disclaimer

This guide is educational and general in nature. Product details, model names, licensing and analyst positions change over time and should be confirmed with official documentation. All product names and trademarks mentioned belong to their respective owners.